

PCI DSS Case Study: Impact in Network Design and Security

By

Yudit María

Thesis submitted in partial fulfillment of the requirements for the
Degree of Master of Science in
Networking and Systems Administration

Rochester Institute of Technology

**B. Thomas Golisano College
of
Computing and Information Sciences**

April, 2010

UMI Number: 1477140

All rights reserved

INFORMATION TO ALL USERS

The quality of this reproduction is dependent upon the quality of the copy submitted.

In the unlikely event that the author did not send a complete manuscript and there are missing pages, these will be noted. Also, if material had to be removed, a note will indicate the deletion.

UMI[®]

Dissertation Publishing

UMI 1477140

Copyright 2010 by ProQuest LLC.

All rights reserved. This edition of the work is protected against unauthorized copying under Title 17, United States Code.

ProQuest[®]

ProQuest LLC
789 East Eisenhower Parkway
P.O. Box 1346
Ann Arbor, MI 48106-1346

**Rochester Institute of Technology
B. Thomas Golisano College
of
Computing and Information Sciences**

**Master of Science in
Networking and Systems Administration**

Thesis Approval Form

Student Name: Yudit María

Thesis Title: PCI DSS Case Study: Impact on Network Design and Security

Thesis Committee

Name

Signature

Date

Charles Border, Ph.D.
Chair

Héctor Mora
Committee Member

Arlene Estévez
Committee Member

Thesis Reproduction Permission Form

Rochester Institute of Technology

B. Thomas Golisano College
Of
Computing and Information Sciences

Master of Science in
Networking and Systems Administration

PCI DSS Case Study: Impact in Network Design and Security

I, Yudit María hereby grant permission to the Wallace Library of the Rochester Institute of Technology to reproduce my thesis in whole or in part. Any reproduction must not be for commercial use or profit.

Date: April, 2010

Signature of Author: _____

ROCHESTER INSTITUTE OF TECHNOLOGY

*B. THOMAS GOLLISANO COLLEGE OF COMPUTING AND INFORMATION SCIENCES
DEPARTMENT OF NETWORKING, SECURITY AND SYSTEM ADMINISTRATION*

Master of Science in Networking and Systems Administration

PCI DSS Case Study

Impact on Network Design and Security

Yudit María

Committee Members:

Héctor Mora

Charles Border

Arlene Estévez

**Project Proposal submitted in partial fulfillment of the requirements
for the Degree of Master of Science in Networking and Systems
Administration**

April, 2010

Abstract

The Payment Card Industry Data Security Standard is a set of twelve security requirements applicable to all institutions and systems handling, storing or transmitting cardholder information. It was created by the main card brands in a united effort to respond to the increasing number of attacks and data breaches cases targeted and linked to card and cardholder data. The standard considers points such as policies design, data security, network architecture, software design, application security, transmission encryption requirements and so on. Being compliant with the standard can be both expensive and traumatic for any business willing to do it. This research analyzes the impact that this compliance achievement process can have on an enterprise. This work is focused on the networking infrastructure and security and application security in general. This is a case study based on a real situation, where real current procedures and implementations were evaluated against the standard requirements regarding networking design, security and applications security. This will provide a benchmark of the situation towards getting the compliance validation in the company subject of this case study.

Table of Contents

Abstract	1
Table of Contents	2
1. Introduction.....	4
2. Antecedents.....	7
2.1. What is it about?	7
2.2. Who is the target?	9
2.3. Some History.....	10
2.4. PCI DSS Compliance Validation	12
2.5. Network Design and PCI DSS Impact	13
3. Motivation and Scope	15
4. Methods, Materials and Procedures.....	16
Procedure	16
5. Case Study Scenario	18
5.1. Regional Situation	20
5.2. Analysis.....	21
6. Network Diagrams Analysis	22
7. Experience and Impact	35
7.1. Cardholder Environment:.....	35
7.2. Firewall Implementation.....	36
7.3. Network and Infrastructure	37
7.4. Access Control	39
Requirement 6: Developing and Maintaining Secure Applications and Systems	40
Requirement 7: Restrict access to cardholder data by business need-to-know	42
Requirement 10: Track and monitor all access to network resources and cardholder data.....	43
Requirement 11: Regularly test security systems and processes	44
7.5. Costs.....	45
8. Findings and Results	47

9. Recommendations	53
10. Conclusions	55
11. Glossary.....	57
12. Bibliography	58
Appendix A.....	61
Appendix B.....	73

PREVIEW

1. Introduction

Credit cards have become a very common way to handle money transactions around the globe. The amount of credit cards being issued keeps going up each year. We have gone a long way since the emission of the first credit card in 1958 (Woolsey & Schulz, 2010). In the USA by June 30, 2009 Visa had 309 million credit cards circulating; Master Card 211 million by September 30, 2009; American Express 54 million by December 31, 2008 and Discover 57.1 million by the same year (Woolsey & Schulz, 2010). From those numbers it can be inferred a total estimate of 631.1 million credit cards were spread all over the country by the end of 2009. Extending those numbers to the globe, and considering debit cards, probably we would be talking about billions of cards doing billions of transactions each day.

Card numbers have always been a temptation for delinquents; cardholder's data (name, account number, pin) is very useful information for identity theft purposes and a cloned credit card can give a vandal immediate money to spend without being notice for a while.

Credit card information and cardholder's data can be illegally collected from several sources such as: garbage, mailboxes, personal records on a hospital or at your workplace, electronically stolen from e-commerce sites, through phishing or with the use of hacking techniques targeted to databases of any company that is known to handle credit card information (Obringer, 2002).

Early in the past decade electronic frauds and hacking techniques started giving serious headaches and represent big losses to companies of all sizes. In 2007 TJX Companies Inc. reported a data breach compromising more than 45 million credit and debit card data; at that moment it was considered the biggest data breach ever (Bosworth, 2007). Before that, in 2005, CardSystems Solutions a payment processor had an intrusion that was presumed having compromised about 40 million credit card

numbers (Krazit, 2005). More recently in 2009, Network Solutions had an incident where about 573,000 debit and credit cards accounts were compromised (Krebs, 2009) while HeartLand Payments Systems had a data breach case, also in 2009, even though they alleged no card data was compromised. It is possible to continue citing cases like these for another couple of paragraphs, but it is enough to illustrate the idea, that those incidents were part of the driving factors (along with disclosure laws and some other particular situations) on the development of enhanced security requirements and standards.

Some years ago before PCI DSS different card brands had made their individual efforts on security initiatives; Visa developed the Cardholder Information Security Program (CISP) and the Account Information Security (AIS) while MasterCard created the Site Data Protection Program (SDP)(Gorge, 2006); American Express had the (DSS) Data Security Standards and Discover Card –(DISC) the Discover Card Information Security and Compliance (Security Assessment, 2007).

Paradoxically, data breaches incidents like those mentioned above made the Payment Card Industry major representatives think that the security topic needed to be addressed as a joint effort in order to make it work. The idea was involving all stakeholders in the protection of their most important assets: cards and cardholder data. That is how the Payment Card Industry Data Security Standard (PCI DSS) was born. The main card brands (American Express, Discover Financial Services, JCB International, MasterCard Worldwide and Visa Inc. International) formed the PCI Security Standards Council that later would release the PCI DSS standard on its first version.

The standard attempts to be a guide on how to approach data security for companies handling credit card transactions in order to minimize the risks of data breaches, identity theft and frauds related to cardholders' data. However getting stakeholders complying with the standard has not been an easy road, and actually represents a transforming process for every company affected by it, worth of a case study.

The following document contains documentation on a case of study about the PCI DSS compliance process for a Dominican financial institution and the impact it has had on its network designing and technological infrastructure security.

PREVIEW

2. Antecedents

2.1. What is it about?

PCI DSS is a Security Standard. Its objective is to protect cardholder data. Its requirements should be applied on any system, server and/or network containing this type of data. Cardholder data includes: PAN: Principal Account Number or Card Number, Cardholder Name, Card Expiration Date, Service Code, Sensitive Authentication Data: Full magnetic stripe data, CAV2/CVC2/CVV2/CID¹ and PINs/PIN blocks. “The Primary Account Number (PAN) is the defining factor in the applicability of PCI DSS requirements and PA-DSS². If PAN is not stored, processed, or transmitted, PCI DSS and PA-DSS do not apply (PCI Security Standards Council LLC, 2008)”

The vast majority of financial institutions (or any institution affected by the standard) do not possess a whole infrastructure or resources exclusively dedicated to handle card transactions and cardholders’ data thus in most cases, not to say in all of them, PCI DSS requirements will affect the entire technological infrastructure and organization; that is the reason why this standard supposes such a big impact on the institutions willing to comply with it.

PCI DSS establishes the following twelve requirements:

Build and Maintain a Secure Network

Requirement 1: Install and maintain a firewall configuration to protect cardholder data.

¹ See Glossary

² Payment Application Data Security Standard

Requirement 2: Do not use vendor-supplied defaults for system passwords and other security parameters.

Protect Cardholder Data

Requirement 3: Protect stored cardholder data.

Requirement 4: Encrypt transmission of cardholder data across open, public networks

Maintain a Vulnerability Management Program

Requirement 5: Use and regularly update anti-virus software or programs

Requirement 6: Develop and maintain secure systems and applications

Implement Strong Access Control Measures

Requirement 7: Restrict access to cardholder data by business need-to-know

Requirement 8: Assign a unique ID to each person with computer access

Requirement 9: Restrict physical access to cardholder data

Regularly Monitor and Test Networks

Requirement 10: Track and monitor all access to network resources and cardholder data

Requirement 11: Regularly test security systems and processes

Maintain an Information Security Policy

Requirement 12: Maintain a policy that addresses information security for employees and contractors.

But, how such common sense directives can be so difficult to achieve? Some of the problems come with the sizes of the companies and the comprehension of the standard as well. Sometimes, misconception of the requirements leads to major difficulties on implementations.

2.2. Who is the target?

PCI DSS applies to any merchants, service providers, and financial institutions that handle, store, process or transmit cardholder data (Bradley, et al., 2007). Merchants are defined as any company that receives a card payment in exchange of a good or service. Service Providers are companies that process, store or transmit cardholder data; they might serve merchants or other service providers (Bradley, et al., 2007).

The standard classifies members, merchants, and service providers into different levels according to the number of transactions they handle. The classification also defines diverse compliance validation procedures and who is responsible for validating the compliance.

Table 1 – Compliance validation summary Table for merchants (www.ncsu.edu, 2005)(Bitter, 2009) (PriceWaterHouseCoopers, 2009)

Merchant Level	Description	Compliance Validation	Validated By
1	More than 6,000,000 annual credit card transactions; Global Merchants identified as level 1 by any Visa region; or <u>Any merchant that has suffered an attack causing account data to be compromised</u> Any business classified as level one by any other credit card company.	Annual On-site data security audit; Quarterly Network Scan Annual external/internal Penetration tests	Qualified Independent security assessor; or Internal audit Approved Scanning vendor (ASV)
2	1,000,000 to 6,000,000 annual transactions	Annual self-assessment; Quarterly Network Scan Annual external/internal Penetration tests	Merchant; Approved Scanning Vendor (ASV)
3	20K to 1,000,000 transactions per year	Annual self-assessment; Quarterly Network Scan Annual external/internal Penetration tests	Merchant; Approved Scanning Vendor (ASV)
4	Less than 20K annual transaction (Visa Credit Card e-commerce transactions) Less than 1,000,000 traditional Visa credit card transactions.	Annual self-assessment (recommended); Quarterly Network Scan (recommended)	Merchant; Approved Scanning Vendor (ASV)

MS NSSA Final Project

Service Provider Level	Description	Compliance Validation
1	More than 300,000 annual transactions	Annual On-site data security audit; Quarterly Network Scan
2	Less than 300,000 annual transactions	Annual self-assessment Questionnaire (SAQ); Quarterly Network Scan

2.3. Some History

PCI DSS was settled as mandatory back in 2004. The latest compliance dates were established for 2007. (Miller). In 2005 several USA major (and minor) retailers and card processors were victims of data breaches incidents that exposed millions of credit card numbers and cardholders confidential information.

According to data contained in the Chronology of Data Breaches (Privacy Rights Clearinghouse, 2010), provided by the privacy rights Clearinghouse from the United States with data compiled from incidents within that country, a total of 345,124,400 records containing sensitive personal information were affected by security breaches in the USA since January 2005 to February 2010. Those breaches occurred on several different entities: universities, hospitals, Stores, banks and other financial institutions.

According to the ITRC (Identity Theft Resource Center, 2008), who keeps statistics on data breaches cases, in 2005 there was a “total of 158 disclosed incidents, potentially affecting more than 64.8 million individuals plus 20 undisclosed victim group populations” (ITRC, 2006); While in 2006 (ITRC, 2007) “At least 312 incidents have been disclosed, potentially affecting more than 19 million individuals: 30% of disclosures involve governmental or military agencies; 28%, educational institutions; 21%, general business; 13%, health care facilities or companies; and 8%, banking, credit or financial services entities”.

In 2007 (ITRC, 2008) there were 446 incidents and 127,725,343 records were exposed (although a record does not necessarily mean an individual because multiple records might be bound to only one individual, this is still a high number). The incidents were

distributed under the following categories: Medical/Healthcare 14.6%, Government/Military 24.7%, Educational 24.9%, General Business 28.9%, 7.0% Banking/Credit/Financial.

In 2009 (ITRC, 2010) a total of 498 breaches incidents were reported with 222,477,043 records exposed. The breaches corresponded to: Medical/Healthcare 13.7%, Government/Military 18.1%, Educational 15.7%, General Business 41.2%, Banking/Credit/Financial 11.4%. For 2010 so far there have been reported 35 breaches affecting 1,422,304 records.

According to Tech//404 Data Loss Calculator (Allied World Assurance Company, 2006) a security incident where 1000 records are compromised can cost a company an average of US\$ 199, 526.00. Imagine cases as the ones contained in the reports mentioned above with numbers of records compromised as large as 2,900,000 records have been compromised (ITRC, 2007).

Credit card brands are aware of the fact that compromised data can cost a lot of money; this is especially true for card/cardholders data. They are also conscious that data breaches can turn into identity theft cases affecting the reputation of their industry. This is especially harmful since the industry could lose plenty of its gains if people start thinking that credit cards are not a safe way to handle their finances.

In order to minimize the risk of having card/cardholder data compromised, losing a lot of money and damaging a reputation, it is necessary to implement comprehensive security measures on the systems and environment where this data resides. It is also necessary to make everybody in the card payment business knowing of the need for collaboration and engagement with security on the infrastructure handling card/cardholder information. That is how PCI DSS came into the scenario.